TECHRISE 3.0

Cybersecurity & DevSecOps Programme · Abia Cohort 3.0 · 2026

PHASE 3 · DEVSECOPS & CLOUD SECURITY

WEEK 09

Threat Intelligence and Professional Reporting

Student Training Manual — AI-First Curriculum

PROGRAMME	COHORT	WEEK	PHASE	METHODOLOGY
Cybersecurity & DevSecOps	**Abia Cohort 3.0**	**9 of 12**	**3 — DevSecOps & Cloud Security**	**AI-First (Manual → AI Enhancement)**

Prepared by the TechRise Curriculum Design Team

Lead: Engr. Eduwem Adam · Co-facilitator: Mr. Akorita-Ifeanyichukwu Nehemiah

TABLE OF CONTENTS

- **Week 9: Threat Intelligence and Professional Reporting**
  - Phase: DevSecOps and Cloud Security (Weeks 9–12)
  - Day 1 — MITRE ATT&CK; Framework
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 2 — Threat Intelligence Levels (Strategic, Tactical, Operational)
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 3 — Professional Report Writing (Executive Summaries)
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 4 — Remediation Roadmaps and AI-Assisted Reporting
    - LEARN · PRACTICE · BUILD · DOCUMENT
  - Day 5 — Review, Assessment & Portfolio
    - LEARN · PRACTICE · BUILD · DOCUMENT
- **Weekly Checklist**
- **Skills Verification**
- **Self-Assessment Quiz**
- **Additional Resources**
- **Looking Ahead — Week 10**

Phase: DevSecOps and Cloud Security (Weeks 9–12) **Week 9 of 12**

WEEK 9: THREAT INTELLIGENCE AND PROFESSIONAL REPORTING

Weekly Overview

This week you transition from technical defender to strategic analyst. You will learn the MITRE ATT&CK; framework — the industry standard for describing adversary behaviour — and how to map your forensic findings to specific tactics and techniques. You will distinguish between strategic, tactical, and operational threat intelligence, and learn to create and share Indicators of Compromise (IOCs). Finally, you will master professional report writing, transforming your technical findings into executive summaries and actionable remediation roadmaps that drive security decisions.

How this week builds on Weeks 1–8

- Week 2 introduced risk assessment frameworks. Week 8 gave you forensic evidence. Now you will map that evidence to MITRE ATT&CK; (the adversary's playbook) and communicate findings to both technical and non-technical audiences.
- Your ability to write professional reports determines whether your recommendations are implemented or ignored.

How this week sets up Weeks 10–12

- Weeks 10–11 cover DevSecOps and cloud security. The reporting skills you learn this week will be used to document pipeline security gates and cloud misconfigurations.
- Week 12 (Capstone) requires a professional report as your final deliverable.

Why this matters in a real security job

- Technical skills get you hired. Communication skills get you promoted.
- A penetration test report that sits unread is worthless. An executive summary that drives budget decisions is invaluable. This week teaches you to write reports that matter.

DAY 1

MITRE ATT&CK; Framework

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Explain the MITRE ATT&CK; framework structure (Tactics → Techniques → Sub-techniques → Procedures)

2. Map a security incident to ATT&CK; tactics

3. Use the ATT&CK; Navigator to visualise defensive coverage

MITRE ATT&CK;

(Adversarial Tactics, Techniques, and Common Knowledge) is a globally accessible knowledge base of adversary tactics and techniques based on real-world observations, providing a common language for describing and defending against cyber threats.

MITRE ATT&CK; — From Abstract to Specific

```
■■■
```

TA0004	Privilege Escalation	Gain higher permissions	Bypass UAC, sudo misconfig
TA0005	Defence Evasion	Avoid detection	Disable logging, obfuscate scripts
TA0006	Credential Access	Steal passwords	Mimikatz, keylogging
TA0007	Discovery	Learn environment	Network scanning, account listing
TA0008	Lateral Movement	Move to other hosts	RDP, PsExec, SMB
TA0009	Collection	Gather target data	Local drives, email, clipboard
TA0010	Exfiltration	Steal data	HTTP upload, DNS tunnelling
TA0011	Command & Control	Call home	Beaconing, reverse shell
TA0040	Impact	Manipulate/destroy	Ransomware, data deletion

Mapping an Incident to ATT&CK; Tactics

```
■■■
```

Step 2 — Map to ATT&CK; Tactics

BASH

```
nano ~/week9_attack_mapping.txt
```

Fill in this table for each tactic: TA0001 (Initial Access), TA0005 (Defence Evasion), TA0008 (Lateral Movement), TA0011 (C2), TA0010 (Exfiltration) — Technique ID, Technique Name, How Attackers Used It.

Step 3 — Verify with MITRE ATT&CK;

Browse to: https://attack.mitre.org — Search for 'SolarWinds' or 'APT29' (attributed group).

Step 4 — AI-Assisted ATT&CK; Mapping

PROMPT

```
Map the 2020 SolarWinds breach to MITRE ATT&CK; tactics. For each tactic, provide the technique ID and a one-sentence description of how attackers accomplished it.
```

Save to week9_ai_attack.txt. Compare with your manual mapping.

■ **ANALYSE THIS**

Did the AI correctly identify TA0005 (Defence Evasion) techniques like signed binary execution? Why is signing important for evasion?

LAB 9.1.2 — Use ATT&CK; Navigator — Defensive Coverage

Objective: Create a heatmap of your detection coverage.

Prerequisites: Internet browser

Step 1 — Open ATT&CK; Navigator

Browse to: https://mitre-attack.github.io/attack-navigator/

Step 2 — Create a Sample Coverage Layer

Select 'Enterprise ATT&CK;' → Create new layer. Colour cells: Green = can detect, Yellow = partial detection, Red = no detection.

For a small company (your lab), mark:

- T1190 (Exploit Public App): Green — you have Snort rules
- T1566 (Phishing): Yellow — email logs only
- T1078 (Valid Accounts): Red — no UEBA

Step 3 — Export and Annotate

Take a screenshot of your heatmap. Save as week9_navigator.png. The Navigator shows gaps in your detection coverage — red cells are where attackers can operate undetected.

■ **ANALYSE THIS**

Why is it valuable to visualise coverage this way? (Hint: Prioritise budget and effort on red cells)

BUILD *(2 Hours)*

BUILD BRIEF

Create an ATT&CK; Coverage Assessment for the organisation you defended in Weeks 5–8.

Audience:

- SOC Manager (technical)

Required sections:

- Executive Summary: number of techniques detected, number with no coverage, top 3 gaps
- Coverage by Tactic: table with all 14 tactics — # techniques covered, total techniques, % coverage
- Top 5 Coverage Gaps: each gap with explanation of why it exists
- Recommended Improvements: for each gap — specific control to implement

DOCUMENT

Writing Prompt:

Write a threat intelligence brief for your CEO about the SolarWinds breach. Audience: Non-technical CEO.

- Include: What happened (attackers poisoned software updates), why it matters (18,000 customers affected), how it relates to your organisation (supply chain risk)
- End with one question for the CEO: e.g., 'Do our vendors sign their updates?'

DAY
2

Threat Intelligence Levels (Strategic, Tactical, Operational)

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Distinguish between strategic, tactical, and operational threat intelligence

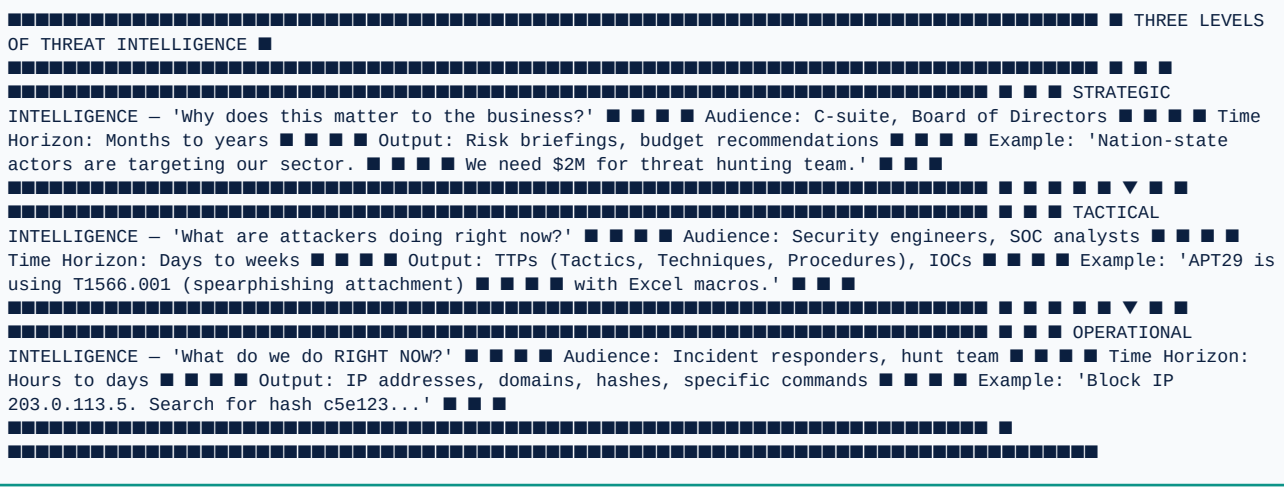
2. Create and share Indicators of Compromise (IOCs)

3. Use STIX/TAXII for machine-readable threat intelligence

THREAT INTELLIGENCE

is evidence-based knowledge about existing or emerging threats that informs decisions to prevent, detect, or respond to cyber attacks, operating at strategic (long-term), tactical (mid-term), and operational (immediate) levels.

Three Levels of Threat Intelligence



Indicators of Compromise (IOCs) — Types and Examples

IOC Type	Format	Example	Detection Method
File Hash (SHA256)	64 hex chars	e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855	AV, EDR
IP Address	IPv4/IPv6	203.0.113.45	Firewall, IDS
Domain Name	FQDN	malicious-domain.com	DNS sinkhole, proxy
URL	Full path	http://evil.com/payload.exe	Proxy, WAF

Registry Key	Windows path	HKLM\Software\Microsoft\Windows\CurrentVersion\Run	HIDS
File Path	System path	C:\Windows\Temp\malware.exe	EDR, FIM
Email Address	user@domain	attacker@evil.com	Email gateway
Network Signature	Snort/Suricata rule	alert tcp ... content:"EVIL"	IDS/IPS

IOC Lifecycle — From Discovery to Retirement



STIX/TAXII — Machine-Readable Intelligence

Standard	Purpose	Example
STIX (Structured Threat Information Expression)	Language to describe cyber threat information (IOCs, TTPs, campaigns)	XML/JSON format for 'IP 203.0.113.5 is malicious'
TAXII (Trusted Automated eXchange of Intelligence Information)	Protocol to share STIX data automatically	SIEM subscribes to feed, gets new IOCs every hour

WHY THIS MATTERS

In the 2021 Colonial Pipeline attack, the FBI obtained the Bitcoin ransom payment's private key (operational intelligence) and shared it via STIX/TAXII to other federal agencies within hours. Without automated sharing, defences would have been delayed by days.

PRACTICE *(2 Hours)*

LAB 9.2.1 — Create IOCs from a Simulated Incident

Objective: Extract IOCs from a forensic report (simulated).

Prerequisites: None — scenario-based

Step 1 — Simulated Incident Summary

Read this incident summary:

```
On January 15, 2025, SOC detected outbound connection to 203.0.113.5:4444 from host WS-023. Forensic analysis revealed: - File downloaded: C:\Windows\Temp\update.exe - SHA256: e3b0c44298fc1c149afbf4c8996fb92427ae41e4649b934ca495991b7852b855 - Registry persistence: HKLM\Software\Microsoft\Windows\CurrentVersion\Run - Process created: cmd.exe /c powershell -enc SQBmAC... - Domain contacted: evil-c2-domain.com (resolves to 203.0.113.5) - Emails sent to: attacker@evil.com
```

Step 2 — Extract and Categorise IOCs

BASH

```
nano ~/week9_iocs.txt
```

Extract and categorise each IOC: SHA256 hash, IP address, domain, file path, registry key, email address.

Step 3 — Determine Which IOCs to Block

- SHA256: Block? Yes — specific malware hash
- IP 203.0.113.5: Block? Yes — known C2, but note risk of blocking legitimate service
- Domain: Block? Yes
- File path: Block? No — legitimate apps use Temp folder; would cause false positives
- Registry key: Monitor but don't block — many legitimate apps use Run key

■ ANALYSE THIS

Why block an IP but not a file path? (Hint: Specificity and false positive rate)

Step 4 — AI-Assisted IOC Validation

PROMPT

```
I have a SHA256 hash from a malware sample. How long should I keep blocking this hash? When would I retire this IOC?
```

Save to week9_ai_ioc.txt. Compare with IOC lifecycle from the lesson.

■ ANALYSE THIS

What factors determine IOC retirement? (Domain sinks, IP reassigned, malware family no longer active)

BUILD *(2 Hours)*

BUILD BRIEF

Create an IOC Sharing Package for the simulated incident in Lab 9.2.1.

Audience:

- Information Sharing and Analysis Center (ISAC) for your industry

Required sections:

- Summary: date discovered, attack type (Cobalt Strike beacon), affected sector
- Network Indicators: IP (block), domain (sinkhole), URL

- Host Indicators: SHA256 hash, file path, registry key
- Email Indicators: attacker email address
- Recommended Actions: firewall block, EDR search, SIEM alert configuration
- TTPs (Tactical Intelligence): TA0011 T1573 (Encrypted Channel), TA0005 T1027 (Obfuscated Files)
- Expiry: IP — review after 30 days; SHA256 — permanent (hash never changes)

DOCUMENT

Writing Prompt:

Write a threat intelligence requirements document for your SOC. Audience: SOC Manager.

- Include: Strategic intelligence needed (annual threat landscape briefing), tactical intelligence needed (weekly TTP updates), operational intelligence needed (hourly IOC feeds)
- For each level: how it will be used in decision-making and sources (commercial feeds, open source, ISACs)

DAY
3

Professional Report Writing (Executive Summaries)

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Distinguish executive summaries from technical findings

2. Write risk ratings that drive action

3. Create a complete penetration test report structure

EXECUTIVE SUMMARY

is a concise overview of security findings written for non-technical decision-makers, focusing on business impact, risk, and recommended actions — not technical details.

Professional Security Report Structure — Pyramid Principle

```
■■■
```

Recommendations	'Prioritise patching web servers'	'Apply patch KB45678 or upgrade to v2.3'

Risk Rating — CVSS + Business Context

```
■■■
```

Objective: Build a complete findings summary.

Prerequisites: None — scenario-based

Create a table with 5 findings. Use fake data or findings from earlier weeks:

Finding	CVSS	Business Impact	Risk Rating	Remediation Timeline
SQL Injection	9.8	Customer data exposure	CRITICAL	24 hours
[Add finding 2]				
[Add finding 3]				
[Add finding 4]				
[Add finding 5]				

■ **ANALYSE THIS**

Which finding would you put FIRST in the executive summary? (The one with highest BUSINESS impact, not necessarily highest CVSS)

BUILD *(2 Hours)*

BUILD BRIEF

Create a Professional Report Template — a complete structure you can reuse for penetration tests or security assessments.

Audience:

- Your future self (and other consultants on your team)

Required sections with placeholders:

- Executive Summary: one paragraph (what we tested, critical findings, urgent actions)
- Key Findings Top 3: with business impact sentence and risk rating for each
- Recommended Actions: Immediate (24h), Short-term (7 days), Long-term (30 days)
- Scope & Methodology: targets, dates, rules of engagement, tools
- Findings Summary Table: ID, Finding, CVSS, Impact, Risk, Status
- Detailed Findings template: Severity, CVSS, Affected Asset, Description, Evidence, Impact, Remediation, References
- Remediation Roadmap: Phase 1 (0-24h), Phase 2 (1-7 days), Phase 3 (30-90 days)
- Appendix: tool versions, raw scan outputs, chain of custody (if forensics)

DOCUMENT

Writing Prompt:

Write an executive summary for a fictional penetration test of 'TechRise Bank' (online banking platform). Findings include: SQL injection in login page (CRITICAL), missing security headers (MEDIUM), outdated SSL certificate (LOW). Audience: CTO (technical but not a security expert). Length: 1 page maximum.

DAY 4

Remediation Roadmaps and AI-Assisted Reporting

LEARN *(1 Hour)*

LEARNING OBJECTIVES

1. Create a phased remediation roadmap (Immediate, Short-term, Long-term)

2. Use AI to assist with report generation while maintaining accuracy

3. Validate AI-generated findings before including in reports

REMEDIATION ROADMAP

is a prioritised, time-bound plan for fixing security vulnerabilities, balancing risk reduction with business constraints.

Phased Remediation Roadmap — Balancing Risk and Resources

```
■■■
```

Remediation	'Write remediation steps for SQL injection. Include: parameterised queries, WAF rule, and input validation. Assume development team uses PHP/MySQL.'

AI VALIDATION CHECKLIST — Before Including in Report

- ■ Are CVE numbers correct? (Verify with NVD)
- ■ Are CVSS scores accurate? (Check against official CVSS calculator)
- ■ Are affected versions right? (Compare with vendor advisory)
- ■ Are remediation commands safe? (Test in lab first)
- ■ Is business impact realistic? (Does it match client's data?)
- ■ Are recommendations actionable? (Specific patches, commands)
- ■ Is the tone professional? (No 'should', 'might', 'could' without justification)
- ■ Does it hallucinate? (Check for non-existent CVEs, wrong vendor names)
- ■ Is it consistent with evidence? (Check screenshots, command outputs)
- ■ Is it client-appropriate? (No jargon for executive summary)

WHY THIS MATTERS

In 2023, a cybersecurity firm used AI to generate a penetration test report. The AI invented a non-existent CVE with a fake CVSS score. The report was delivered to a Fortune 500 client. The client discovered the error and terminated the contract. AI is a tool — but YOU are responsible for every word in your report.

PRACTICE *(2 Hours)*

LAB 9.4.1 — Create a Remediation Roadmap

Objective: Prioritise findings and assign timelines.

Prerequisites: None — scenario-based

Step 1 — Review Findings

Finding	CVSS	Business Impact	Effort to Fix
SQL injection in customer portal	9.8	PII exposure (50k records)	4 hours (patch)
Default admin/admin on router	7.5	Network compromise	5 minutes (change password)
Outdated TLS 1.0 on email server	5.3	Man-in-the-middle risk	2 hours (reconfigure)
Missing CSP header on blog	4.3	XSS risk	30 minutes (config change)
Unpatched Apache on internal server	8.2	RCE, but internal only	1 hour (update package)

Step 2 — Assign to Phases

Create a roadmap table with columns: Phase | Findings | Why this priority?

Sample answer:

- Immediate: Router default password (5 min fix, prevents immediate compromise)
- Short-term: SQL injection (customer data at risk), Apache patch
- Long-term: TLS upgrade, CSP header (lower risk, requires coordination)

■ ANALYSE THIS

Why is the 5-minute router password fix in IMMEDIATE, but the 30-minute CSP header in LONG-TERM? (Risk: default admin password = immediate network takeover; CSP missing = theoretical XSS)

LAB 9.4.2 — AI-Assisted Report Generation (With Validation)

Objective: Use AI to generate a finding, then validate it.

Prerequisites: AI assistant available

Step 1 — Generate Finding with AI

PROMPT

```
Write a penetration test finding for SQL injection on a customer portal. Include: vulnerable URL,
attack example, impact, remediation. Write for a technical audience.
```

Save to week9_ai_finding.txt.

Step 2 — Validate the Finding

- Is the vulnerable URL realistic? (yes/no)
- Does the attack example work? (test mentally)
- Is the impact accurate? (yes/no)
- Are remediation steps safe and correct? (yes/no)
- Are there any hallucinations? (non-existent CVEs?)

Step 3 — Correct the Finding

Edit the AI's output to fix any errors. Save as week9_ai_finding_corrected.txt.

■ ANALYSE THIS

Did the AI recommend parameterised queries? Did it mention input validation as defence-in-depth (not primary fix)? Many AIs get this wrong.

BUILD *(2 Hours)*

BUILD BRIEF

Create a Complete Report Extract — one detailed finding, generated with AI assistance then human-validated.

Scenario:

- You discovered vsftpd 2.3.4 backdoor (CVE-2011-2523) on a client's FTP server during a penetration test

Required sections (use AI to draft, then validate each):

- Finding Title: vsftpd 2.3.4 Backdoor (CVE-2011-2523)
- Severity: CRITICAL | CVSS: 10.0 | Affected Asset: ftp-client.example.com
- Description: AI draft → human edit
- Evidence: Manual — paste your actual Nmap scan output from Week 4
- Impact: AI draft → human edit, focused on business impact
- Remediation: AI draft → human edit, must be actionable
- References: CVE-2011-2523 + MITRE ATT&CK; TA0001 T1190
- Validation Notes: what you corrected in AI's draft + what you verified from source

DOCUMENT

Writing Prompt:

Write an AI usage policy for your security team. Audience: Team members who might use AI for report writing.

- Include: What AI CAN be used for (drafting, grammar checking, summarising), what AI CANNOT be used for (final approval, inventing evidence)
- Include the mandatory validation checklist from today's lesson
- Include consequences of submitting unvalidated AI content (reputation risk, contract termination, legal liability)

DAY
5

Review, Assessment & Portfolio

LEARN *(1 Hour) — Week Review*

LEARNING OBJECTIVES

1. Recall and apply all Week 9 threat intelligence and reporting concepts

2. Complete portfolio entries for reporting skills

3. Articulate how threat intelligence drives defensive decisions

Week 9 Mind Map — Threat Intelligence & Reporting



AI Integration Reflection — Week 9

- This week you used AI to draft report sections and generate intelligence summaries.
- Key insight: AI is excellent at formatting and grammar, but struggles with accurate business impact assessment and may hallucinate CVEs.
- Your validation skill is critical — you are the expert, AI is the assistant.

PRACTICE *(2 Hours) — Skills Assessment Labs*

LAB 9.5.1 — ATT&CK; Tactic Matching

Objective: Match each attacker action to the correct ATT&CK; tactic.

Prerequisites: No notes

Match each action to the correct tactic (TA0001–TA0040):

1. Attacker downloads Mimikatz to dump passwords: _____

2. Attacker creates a new domain admin account: _____

3. Attacker scans internal network for open ports: _____
4. Attacker sends phishing email with malicious link: _____
5. Attacker encrypts all files and demands Bitcoin: _____

LAB 9.5.2 — IOC Classification

Objective: Classify each as STRATEGIC, TACTICAL, or OPERATIONAL.

Prerequisites: No notes

a) 'Nation-state actors are targeting the energy sector.' → _____
b) 'Block IP 203.0.113.5 immediately.' → _____
c) 'APT29 uses T1566.001 (spearphishing attachment).' → _____
d) 'Allocate $5M for next year's security budget.' → _____
e) 'Search for SHA256 hash e3b0c442...' → _____

LAB 9.5.3 — Risk Rating with Business Context

Objective: Assign FINAL RISK for each scenario.

Prerequisites: No notes

1. Public-facing marketing blog (no PII) with RCE vulnerability (CVSS 9.8)
2. Internal HR database (employee SSNs) with default admin/admin (CVSS 7.5)
3. Development server with no customer data, SQL injection (CVSS 8.2)
4. Customer payment portal (credit cards) with outdated TLS (CVSS 5.3)

LAB 9.5.4 — Report Section Identification

Objective: Match report section to its audience.

Prerequisites: No notes

Section	Audience (CTO / Engineer / Both)
Executive Summary	
CVSS scores and CVE numbers	
Screenshot of SQL injection	
Remediation roadmap timeline	
Command to patch vulnerability	

LAB 9.5.5 — AI Validation Exercise

Objective: Identify and document an AI hallucination.

Prerequisites: AI assistant available

Ask an AI: 'What is the remediation for CVE-2024-12345?'

Then check: Does the CVE exist? (Search NVD). If it doesn't exist → AI hallucination. If remediation is wrong → incorrect. Document your findings.

BUILD *(2 Hours) — Portfolio Entry*

BUILD BRIEF

Create your Week 9 Portfolio Entry — comprehensive document demonstrating threat intelligence and reporting skills.

Required sections:

- 1. MITRE ATT&CK; Mapping: map vsftpd exploitation from Week 4 — tactic, technique, and why
- 2. Threat Intelligence Levels: provide one example of each (strategic, tactical, operational) from your own experience
- 3. IOC Package: for the vsftpd incident (Week 4) — SHA256, IP address, file path, registry (if applicable)
- 4. Report Extract: complete validated finding from your Day 4 BUILD section (vsftpd backdoor with all sections)
- 5. Remediation Roadmap: phased plan for the vsftpd finding — Immediate (0-24h), Short-term (1-7d), Long-term (30d+)
- 6. AI Integration Log: prompt used, what AI got right, what AI got wrong, what you corrected, validation steps performed
- 7. Self-Reflection: most valuable reporting technique, most challenging concept, how you will use threat intelligence in your career

Quality standard:

- All sections completed. AI log shows specific corrections (not 'nothing was wrong'). Risk ratings include business justification. Remediation phases are realistic.

DOCUMENT *(1 Hour) — Week Summary*

DOCUMENT

Writing Prompt:

Write a threat intelligence strategic brief for your CISO. Assume a zero-day vulnerability (CVE-2025-0001 — fictional) affecting your industry's primary software vendor. Audience: CISO (technical but strategic).

- Include: What is known about the vulnerability (CVSS 9.8, RCE)
- Immediate operational actions (block at firewall, search for IOCs)
- Tactical recommendations (deploy virtual patch, monitor vendor for patch)
- Strategic recommendations (vendor risk management programme, diversify software vendors)
- Budget ask ($250k for threat hunting team)

Weekly Checklist (Student-Facing)

- ■ I can explain MITRE ATT&CK; structure (Tactics → Techniques → Sub-techniques) without notes
- ■ I have mapped a real breach to at least 5 ATT&CK; tactics
- ■ I have used ATT&CK; Navigator to visualise defensive coverage
- ■ I can distinguish strategic, tactical, and operational intelligence
- ■ I have created an IOC package from a forensic incident
- ■ I have written a complete penetration test finding (all sections)
- ■ I have created a phased remediation roadmap
- ■ I have used AI to draft report content and validated it
- ■ I have identified and corrected an AI hallucination
- ■ My Week 9 Portfolio Entry is complete

Skills Verification

Skill	How to Demonstrate It	Pass Standard
ATT&CK; mapping	Map vsftpd exploit to tactic and technique	TA0001 (Initial Access), T1190
Intelligence levels	Provide correct classification for 5 scenarios	4/5 correct
IOC creation	Create IOC package from incident	All 4 IOC types present
Risk rating	Apply business context to CVSS	Correct final rating with justification
Report writing	Complete finding with all required sections	Professional format, no placeholders
AI validation	Find and correct AI error in finding	Specific correction documented

Self-Assessment Quiz

Instructions

- No notes — answer from memory.
- Write on separate sheet.
- Key in Instructor Notes.

Definition Questions

1. Define MITRE ATT&CK.; What is the difference between a tactic and a technique?
2. Define Threat Intelligence. What are the three levels (strategic, tactical, operational) and who is the audience for each?

Concept Identification

3. What is the difference between STIX and TAXII? Which one is a language, and which is a transport protocol?
4. In a penetration test report, what is the difference between an executive summary and a detailed finding?

Output Interpretation

5. A client says: 'Our risk assessment team rated this vulnerability MEDIUM because CVSS is 5.3.' You know the affected system contains PII for 1 million customers. What is wrong with their risk rating? What should it be?
6. The ATT&CK; Navigator shows all green cells. Why is this likely false? What does it indicate about the organisation's security posture?

Scenario Questions

7. You discover a SQL injection vulnerability on a client's public-facing website. The client says 'patching will take 6 months because we need to rewrite the application.' Propose three actions they can take immediately while waiting for the rewrite.
8. Your SOC is overwhelmed with 10,000 alerts per day. Using MITRE ATT&CK;, how would you prioritise which techniques to focus detection on? (Hint: Look at threat intelligence about which techniques are most commonly used against your industry)

Connection to Previous Week

9. In Week 8, you performed memory forensics and found a suspicious process. How would you map this finding to MITRE ATT&CK;? What tactic and technique would you assign? Why is this mapping valuable for the incident response report?

AI Enhancement

10. An AI generates this remediation for SQL injection: 'Use a Web Application Firewall (WAF) to block SQL injection. This completely fixes the vulnerability.' Validate this statement. Is it correct? What is the primary fix for SQL injection? Where would you place this recommendation in the remediation roadmap?

Additional Resources

Official Documentation

- MITRE ATT&CK; — Full knowledge base: https://attack.mitre.org/
- ATT&CK; Navigator — Visualisation tool: https://mitre-attack.github.io/attack-navigator/
- STIX/TAXII Standards: https://oasis-open.github.io/cti-documentation/

Free Learning Platforms

- TryHackMe — MITRE ATT&CK; Room (Free, 3 hours): https://tryhackme.com/room/mitre
- TryHackMe — Threat Intelligence Room (Free, 2 hours): https://tryhackme.com/room/threatintel

Written References

- 'Threat Intelligence and Reporting' by SANS Institute — Whitepaper: https://www.sans.org
- 'Writing Penetration Test Reports' by Georgia Weidman — Guide
- CVSS v3.1 Calculator (verify your scores): https://www.first.org/cvss/calculator/3.1

Professional Community

- ATT&CK; Community — Slack, forums: https://attack.mitre.org/resources/community/
- MISP Project — Threat intel sharing: https://www.misp-project.org/communities/
- AlienVault OTX — Free threat intelligence: https://otx.alienvault.com

Looking Ahead — Week 10

Preview — What's Coming in Week 10

- Phase 3: DevSecOps & Cloud Security begins in full
- DevOps lifecycle (Plan → Code → Build → Test → Release → Operate → Monitor)
- Shift-left security — finding vulnerabilities earlier in development
- Git version control and secure repository practices
- CI/CD pipelines with GitHub Actions
- SAST (Semgrep/Bandit), dependency scanning, secrets detection
- AI-enhanced code review and security test generation

What to Review Before Week 10

- Week 3 automation (bash/Python scripts) — DevSecOps builds on scripting
- Week 5 web vulnerabilities — SAST tools find these in code
- Week 6 SIEM — monitoring CI/CD pipeline logs

Instructor Note — Week 9 Complete

- Week 9 completes the transition from Blue Team (Weeks 5–8) to Phase 3 (DevSecOps).
- Students now have: ATT&CK; framework knowledge, IOC creation skills, professional report writing capability.
- These communication skills will be exercised in every remaining week (10–12).
- Week 12 Capstone requires a professional report — the templates from this week will be used directly.